

Attack Surface Management (ASM)

Mapeo de Superficie de Ataque Web

AIACO Corp — Portal Corporativo · aiaco.netlify.app

ESTUDIANTE / PRACTICANTE

Jesús Alejandro Rodríguez Medina

ROL

DevSecOps / Analista de Ciberseguridad Jr.

ORGANIZACIÓN / PROYECTO

AIACO Corp

ÁREA / DEPARTAMENTO

Seguridad de la Información /
Infraestructura

CICLO / SPRINT

Sprint 2 (Semana 2)

FECHA DE EJECUCIÓN

Julio de 2026

ISO/IEC 27001 · A.12.6.1

NIST SP 800-115

OWASP WSTG v4.2

1. Ficha General del Documento

Campo	Detalle Corporativo / Académico
Estudiante / Practicante	Jesús Alejandro Rodríguez Medina
Rol	DevSecOps / Analista de Ciberseguridad Jr.
Organización / Proyecto	AIACO Corp
Área / Departamento	Seguridad de la Información / Infraestructura
Fecha de Ejecución	Julio de 2026
Estado del Sprint	COMPLETADO (100%)

2. Resumen Ejecutivo

El presente reporte documenta las actividades ejecutadas durante el Sprint 2, correspondiente al proyecto de gestión de superficie de ataque (Attack Surface Management – ASM) para **AIACO Corp**. El objetivo principal de este ciclo fue realizar el mapeo de superficie de ataque web del portal corporativo (**aiaco.netlify.app**), identificando componentes públicos, puertos, tecnologías y posibles vectores de exposición, sin recurrir a técnicas de explotación activa.

Como resultado de la auditoría técnica, se determinó que la infraestructura web presenta un nivel de riesgo **BAJO**, caracterizado por una superficie reducida gracias al modelo de arquitectura serverless administrado. No se detectaron fugas de datos sensibles, credenciales expuestas ni directorios administrativos accesibles. Las principales áreas de mejora se identificaron en la capa de hardening de cabeceras HTTP defensivas.

NIVEL DE RIESGO

BAJO

HALLAZGOS
CRÍTICOS

0

HALLAZGOS
INFORMATIVOS

2

HISTORIAS DE
USUARIO

3/3

3. Objetivos e Historias de Usuario (Sprint Scope)

3.1. Objetivos Técnicos

- Configurar y validar el entorno de pruebas de ciberseguridad híbrido (Windows / Kali Linux).
- Ejecutar técnicas de fingerprinting y reconocimiento pasivo sobre el activo web objetivo.
- Realizar escaneo de servicios, puertos y enumeración de encabezados HTTP.
- Efectuar fuzzing (fuerza bruta de rutas) para descartar fugas de archivos sensibles o respaldos.

3.2. Historias de Usuario (Metodología Agile/SCRUM)

ID	Historia de Usuario	Criterio de Aceptación	Estado
HU-01	Como analista ASM, quiero preparar las herramientas de auditoría para asegurar la repetibilidad de las pruebas.	Herramientas Nmap, Gobuster y Wappalyzer instaladas y verificadas por versión.	Completado
HU-02	Como analista ASM, quiero auditar las tecnologías y puertos expuestos del sitio web para determinar el vector inicial.	Matriz de puertos (80, 443) y tecnologías identificadas sin afectar disponibilidad.	Completado
HU-03	Como analista ASM, quiero auditar las rutas públicas para verificar que no existan datos sensibles en producción.	Análisis de respuestas HTTP (200, 403, 404) completado sin hallazgos críticos.	Completado

4. Metodología y Entorno de Trabajo

La auditoría se ejecutó bajo una metodología de **Caja Negra (Black-Box)**, siguiendo los lineamientos de la guía **NIST SP 800-115** (Technical Guide to Information Security Testing and Assessment).

Elemento	Detalle
Host Operativo	Windows 11 Pro
Entorno de Ejecución Ofensiva	Kali Linux (Máquina Virtual)
Target de Pruebas	aiaco.netlify.app
Herramientas Utilizadas	Nmap 7.95, Gobuster 3.x, Wappalyzer, SecurityHeaders.com

nmap 7.95

gobuster 3.x

wappalyzer

securityheaders.com

5. Ejecución Técnica y Resultados Obtenidos

Fase 1 — Verificación e Instalación de Herramientas

Se realizó el despliegue del herramental en Kali Linux verificando la integridad de binarios (Nmap versión 7.95 y configuración exitosa de Gobuster mediante repositorios oficiales).

Fase 2 — Reconocimiento y Fingerprinting

Identificación de tecnologías (pasivo): a través de la extensión Wappalyzer se determinó la siguiente pila tecnológica:

- **Proveedor Cloud / Hosting:** Netlify (Serverless Static Hosting)
- **CSS Framework:** Tailwind CSS
- **Assets Externos:** Google Font API

No se detectaron manejadores CMS (WordPress) ni lenguajes dinámicos de servidor expuestos.

Escaneo de puertos y servicios (Nmap):

53/TCP
DNS — Abierto

80/TCP
HTTP — Abierto
(redirección a HTTPS)

443/TCP
HTTPS — Abierto (Netlify)

22 · 21 · 3306 ·
3389
SSH / FTP / MySQL /
RDP — Cerrados/
Filtrados

Auditoría de métodos y cabeceras HTTP:

- Métodos permitidos: **GET, HEAD, POST, OPTIONS** (métodos peligrosos PUT, DELETE y TRACE desactivados).
- Cabecera crítica presente: **Strict-Transport-Security** (HSTS activo).

Fase 3 — Descubrimiento de Contenido (Content Discovery)

Se ejecutó fuerza bruta de URIs utilizando Gobuster y la lista de diccionario estándar de Kali Linux.

Categoría	Resultado
Rutas públicas válidas (200)	/index.html, /servicio
Rutas protegidas / denegadas (403)	/company, /community, /comments
Fugas de información	Cero (0) hallazgos — sin archivos .env, .git, backups .zip, scripts SQL ni paneles administrativos

6. Matriz de Exposición y Evaluación de Riesgos

Para la clasificación de los hallazgos se utilizó el estándar OWASP Risk Rating Methodology.

ID	Descripción Técnica	Impacto	Probabilidad	Nivel de Riesgo
FIND-01	Ausencia de cabeceras HTTP de hardening: falta de Content-Security-Policy (CSP), X-Frame-Options y X-Content-Type-Options.	Bajo	Medio	Informativo / Bajo
FIND-02	Fuga informativa de servidor: la cabecera "Server: Netlify" expone el proveedor de infraestructura.	Muy Bajo	Alto	Informativo

7. Plan de Mitigación y Recomendaciones (Blue Team)

Aunque el sitio web se encuentra asegurado a nivel de infraestructura, se sugieren las siguientes acciones de endurecimiento (hardening):

- 1 **Configurar Content Security Policy (CSP):** definir políticas en las cabeceras HTTP de Netlify para restringir el origen de scripts permitidos y prevenir ataques Cross-Site Scripting (XSS).
- 2 **Prevenir Clickjacking:** incluir la cabecera *X-Frame-Options: DENY* o *SAMEORIGIN* para evitar que el portal sea cargado dentro de marcos maliciosos.
- 3 **MIME-Type Sniffing Protection:** habilitar la cabecera *X-Content-Type-Options: nosniff*.

8. Aprobación y Conformidad

El presente reporte certifica el cumplimiento exitoso del plan de trabajo trazado para el Sprint 2 dentro del programa de Prácticas Profesionales en Ciberseguridad.

Jesús Alejandro Rodríguez Medina
Practicante de Ciberseguridad / DevSecOps
AIACO Corp

✓ SPRINT COMPLETADO